ESTADO DE PREPARACIÓN TÉCNICA PARA ENFRENTAR UN PROCESO FORENSE. SIMETRIK

Esta versión: Mayo 2023.

Resumen Ejecutivo

Este documento contine una revisión del estado de preparación de SIMETRIK ante un eventual evento de seguridad. Para hacer este proceso hemos realizado múltiples reuniones con el personal de IT, seguridad y otras áreas de la organización. Adicionalmente hemos revisado material entregado por SIMETRIK asociado a algunos de sus procedimientos y arquitectura.

En la sección de Metodología describimos el significado de cada escala utilizada y su impacto.

En sentido general creemos que SIMETRIK tiene una arquitectura de cómputo robusta y bien administrada (incluyendo al personal que conocimos). Como era de esperar, algunos procesos pueden mejorarse de cara no solo a un eventual proceso forense sino a su prevención, es decir mejorando la posición de seguridad organizacional.

En general, hay tres (3) procesos que se pueden ver más afectados en el esquema forense. El primero, es el de identificación de orígenes del incidente. La razón de esto está asociada a que la arquitectura de seguridad no cubre a toda la organización. Por lo tanto, un atacante podría obtener cuentas y accesos en una estación y luego acceder con ellas a servidores u otros equipos críticos. El equipo forense tendría serias dificultades para obtener la información del origen del evento. En recientes incidentes en Colombia y la región ese ha sido el modo usado por los atacantes.

Adicionalmente, los procesos de preservación y evaluación de la relevancia durante la recolección de evidencias también tienen un nivel bajo de cumplimiento debido a falta de detalle en ambos procesos. Es muy importante señalar que ambos procesos se realizan casi siempre ANTES de la llegada del equipo forense y debido a la volatilidad de las evidencias debe ser ejecutado por un equipo interno especializado. Si las evidencias no son recolectadas correctamente, el forense se encontrará en problemas que pueden ir desde la falta de información, pérdida de detalles o incluso la inadmisibilidad técnica de alguna.

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

Velasco & Calle D'Aleman
Derecho de TIC / Ciberseguridad

Desde el punto de vista de tipología de ataques (sobre estadísticas de ocurrencia en 2022 que están señaladas en el texto) los incidentes de malware interno y suplantación de identidad son los que en peor condición se encuentran.

Es muy importante enfatizar que el objetivo de este documento no es hacer una evaluación de controles o de la posición de seguridad organizacional, sino encontrar, a partir de la forma en que son operados y diseñados elementos que pudiese afectar el proceso forense ya sea impactando el proceso de preservación de evidencias o la disponibilidad de las fuentes de información. Por lo tanto, no debe tomarse este dictamen como una ponderación del estado de seguridad organizacional.

Les sugerimos hacer una revisión más profunda de los temas de arquitectura de seguridad y procedimientos. Posiblemente, haciendo algunos ajustes a estos, la posición ante un proceso forense mejore significativamente.

Creemos que también se debe hacer una revisión de procedimientos de manera que cumplan no solo desde el punto de vista técnico, sino igualmente aquellos elementos que solicita el regulador u otros entes de control.

Adicionalmente, el incumplimiento de algunos de los preceptos que hemos mencionado en este informe, pueden afectar el proceso de contratación de pólizas de ciberseguridad o de reclamaciones.

El equipo de Velasco Calle D'Aleman agradece al personal técnico de Simetrik involucrado por su aporte, apoyo y sinceridad.

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

Velasco & Calle D'Aleman
Derecho de TIC / Ciberseguridad

Tabla de contenido

ESTADO DE PREPARACIÓN TÉCNICA PARA ENFRENTAR UN PROCESO FORENSE. SIMETRIK 1

Resumen Ejecutivo 1

I. Metodología 4

¿Qué debe contener un informe forense bien realizado? 4

Descripción metodológica 4

Estado de Preparación 8

II. Disponibilidad de fuentes de información. 8

III. Procedimientos de preservación de evidencia 10

IV. Procedimiento de evaluación de la relevancia forense de las evidencias 11

V. Tiempo de preservación de evidencias 13

VI. Determinación del origen real del incidente 13

VII. Determinación del alcance del incidente 14

VIII. Determinación de los controles afectados. 15

IX. Nivel de preparación global para realizar forense sobre los ataques más comunes 17

X. Sobre la posible necesidad de reportar un incidente de seguridad. 19

Conclusiones 25

XI. REQUISITOS BASICOS DE UN SERVICIO SOC COSTO EFECTIVO 26

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

I. Metodología

¿Qué debe contener un informe forense bien realizado?

Aunque no hay un estándar completamente aceptado sobre un informe forense (por ejemplo ver este documento del gobierno inglés[1]) hay elementos que siempre deben estar presentes y que han guiado esta auditoría. Por lo tanto deben poderse definir:

1- Origen del incidente (que puede ser múltiple)
2- Modo de operación de los atacantes (referido a estándares como Mitre)
3- Tipo de incidente
4- Timeline
5- Alcance interior del incidente
6- Alcance exterior del incidente
7- Impacto del incidente
8- Fuga de información general
9- Fuga de información con datos personales
10- Controles comprometidos o que fallaron (y por qué)
11- Usuarios comprometidos
12- Plan de acción a corto y mediano plazo para evitar repeticiones.

Descripción metodológica

Este proceso se realizó en 2 fases principales. En la primera de ellas se realizaron entrevistas con el personal técnico, incluyendo los encargados de seguridad, TI y auditoria (o sus equivalentes funcionales). Estas entrevistas se realizaron siguiendo un set de preguntas predefinidas por Velasco Calle D'Aleman cuyo objetivo principal era establecer las prácticas documentadas o no que podrían tener impacto en el nivel de preparación del equipo encargado ante un evento que amerite esfuerzo forense. Durante estas entrevistas se evaluaron los siguientes elementos:

-Arquitectura de Seguridad

[1] https://www.gov.uk/government/publications/best-practice-statement-forensic-auditing/best-practice-statement-forensic-auditing

CONFIDENCIAL

-Gestión de Actualizaciones

-Gestión de usuarios y roles

-Monitoreo de la seguridad

-Ciclo de desarrollo de aplicaciones

-SGSI

-Preservación de evidencias

-Control de cambios

-Preparación del personal

-Gestión de actualizaciones.

Es muy importante enfatizar que el objetivo de este documento no es hacer una evaluación de controles o de la posición de seguridad organizacional, sino encontrar, a partir de la forma en que son operados elementos que pudiese afectar el proceso forense ya sea impactando el proceso de preservación de evidencias o la disponibilidad de las fuentes de información.

En la segunda fase se evaluó documentación entregada por SIMETRIK.

Dentro de cada elemento descrito previamente, se hizo énfasis en los siguientes puntos:

1. Disponibilidad de fuentes de información
2. Procedimientos de preservación de evidencia
3. Procedimiento de evaluación de la relevancia forense de las evidencias
4. Tiempo de preservación
5. Determinación del origen real del incidente
6. Determinación del alcance del incidente
7. Determinación de los controles afectados.

Los puntos 1 al 4 están asociados a el proceso general de recopilación de evidencias. Los puntos 5 al 7 están asociados a la exactitud y completitud del proceso forense y a la emisión de recomendaciones para evitar repeticiones del informe.

CONFIDENCIAL

Como estándares de referencia hemos usado las normas ISO 27037[2], 27041[3], 27042[4] y las recomendaciones NIST SP-86[5], SP 1800-34B[6], SP 1800-8B[7], SP 800-160[8], SP 800-172[9], SP 800-53[10]. Para la definición de técnicas de ataque hemos usado MITRE ATTACK[11]. A estos referentes se ha sumado la experiencia de nuestro equipo de trabajo en la realización de múltiples casos forenses en Colombia y el exterior.

Para la clasificación del estado de preparación hemos usado una escala de 1 a 4. El significado de cada valor se describe en la Tabla 1.

CONFIDENCIAL

[2] ISO/IEC 27037:2012 - Information technology — Security techniques — Guidelines for identification, collection, acquisition and preservation of digital evidence

[3] ISO/IEC 27041:2015 - Information technology — Security techniques — Guidance on assuring suitability and adequacy of incident investigative method

[4] ISO/IEC 27042:2015 - Information technology — Security techniques — Guidelines for the analysis and interpretation of digital evidence

[5] SP 800-86, Guide to Integrating Forensic Techniques into Incident Response | CSRC (nist.gov)

[6] https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1800-34.pdf

[7] https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1800-8.pdf

[8] https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-160v2r1.pdf

[9] https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-171r2.pdf

[10] https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf

[11] MITRE ATT&CK®

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

Tabla 1 Escala para medir el nivel de preparación para un eventual proceso forense.

Nivel	Significado
1	Los procedimientos (de facto o documentados) no tienen en cuenta la preservación de evidencias. Faltan fuentes de información imprescindibles para el proceso forense.
2	Los procedimientos (de facto o documentados) mencionan algunos temas de preservación de evidencias, aunque no definen métodos de recolección, clasificación e inventario de fuentes de información. Pueden faltar fuentes importantes de información.
3	Los procedimientos (de facto o documentados) mencionan algunos temas de preservación de evidencias, aunque faltan algunas definiciones sobre métodos de recolección, clasificación e inventario de fuentes de información. Pueden faltar fuentes importantes de información.
4	Los procedimientos (documentados) mencionan con claridad temas de preservación de evidencias, definiendo los métodos de recolección, clasificación e inventario de fuentes de información. Las fuentes de información son suficientes para responder a los casos forenses más habituales.

CONFIDENCIAL

Estado de Preparación

II. Disponibilidad de fuentes de información.

Nivel de preparación: 3

La arquitectura de cómputo está basada en servicios en nube por lo que la estrategia de seguridad se ha concentrado en ella. Por lo tanto, luego de analizar los detalles contratados es posible esperar un nivel adecuado de información desde la nube en los siguientes elementos:

1. Tráfico entrante/saliente
2. Bitácoras de acciones sobre aplicaciones
3. Cambios en las aplicaciones
4. Antivirus
5. Autenticación
6. Monitoreo a nivel de servidores[12]

Hallazgos:

Los siguientes elementos deben ser adecuados de acuerdo al criterio de la organización. Sin detrimento de lo anterior, no tenerlos puede afectar la capacidad y resultados de un proceso forense.

1. El monitoreo planteado no incluye estaciones de trabajo. Por lo tanto, en un proceso forense podría no contarse con esta información, muy valiosa para detectar orígenes de incidentes.
2. No hay disponible información de las conexiones locales desde/hacia estaciones de trabajo.
3. No hay información específica sobre manejo de cuentas privilegiadas.
4. No hay esquemas automatizados para detectar cambios (File Integrity Monitor)
5. No hay un esquema de control de cambios que incluya arquitectura de TI.

Recomendaciones:

1- El esquema de seguridad debe incluir todos los elementos, incluso estaciones de trabajo. Ver criterio de Zero Trust de NIST[13]. Este esquema debe incluir no solo las conexiones hacia la nube sino también el ambiente de seguridad local.

[12] Al momento de realizar la revisión se estaba contratando el servicio SOC. Por lo tanto, esta evaluación particular pudiese cambiar notablemente al evaluar la cobertura por casos de uso (reglas de correlación) del servicio luego de estabilizado. Sugerimos que este proceso de valide al menos 6 meses luego de iniciado el servicio SOC.
[13] Ver https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf

CONFIDENCIAL

2- Las cuentas con alto nivel de privilegios (IT, gerentes, usuarios con accesos administrativos o a datos críticos) deben ser tratadas de manera diferenciadas. Estas cuentas suelen ser blanco de ataques. Sugerimos ver la implementación de PAM. El documento en pie de página tiene una referencia específica para AWS[14]. Además sugerimos el documento "PAM for Cloud" que está referenciado en el propio texto señalado. Adicionalmente, sugerimos ver la guía NIST sobre manejo de identidades privilegiadas[15]. Los sistemas PAM son parte de esquemas de identidad (IAM), pero pueden ser desplegados y manejados de manera independiente.
3- Sugerimos enfáticamente configurar un sistema de detección de cambios de integridad (FIM). Esta función puede ser dada por el sistema SOC que contraten o con herramientas independientes. En los sistemas FIM existen dos tipos: los basados en cambios reflejados en bitácoras y los criptográficos. Ambos tienen ventajas y desventajas. El primero, suele producir menos sobrecarga computacional, pero está limitado a la granularidad y presencia de bitácoras. Esto implica que no pueden identificar algunos tipos de cambios. Los segundos son más robustos desde el punto de vista de detección, pero se deben ejecutar como tareas programadas lo que aumenta el tiempo entre que un cambio es realizado y se detecta. Sugerimos ver documento NIST sobre el tema[16] y ver documentación de fabricantes, por ejemplo TRIPWIRE.[17] Como ambos esquemas pueden coexistir en una arquitectura híbrida, sugerimos que se haga de esta forma.
4- Sugerimos establecer formalmente un esquema de control de cambios. Como referencia se puede tomar lo especificado en ITIL, ver documento de IBM[18]. Debe notarse que los puntos PAM y FIM señalados previamente son imprescindibles para un proceso de control de cambios correcto. Además, sugerimos ver la norma ISO270001:2022 que tiene dimensiones dedicadas a control de cambios. Nótese que un proceso real y correcto de control de cambios tiene que incluir la fiscalización completa, para detectar cambios que no pasaron por aprobación o que son distintos de los aprobados. Este esquema debe incluir TODA la arquitectura, no solo aplicaciones. Sugerimos ver también la recomendación ISM3 en los acápites referidos a Controles de Cambio (2) [19]

CONFIDENCIAL

[14] https://delinea.com/blog/pam-and-aws-keeping-pace-with-aws-privileged-accounts
[15] https://www.nccoe.nist.gov/sites/default/files/legacy-files/fs-pam-fact-sheet.pdf
[16] https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1800-24.pdf
[17] https://www.tripwire.com/state-of-security/file-integrity-monitoring
[18] https://www.ibm.com/topics/it-infrastructure-library
[19] https://ism3.com

III. Procedimientos de preservación de evidencia

Nivel de preparación: 2

La organización cuenta con un procedimiento formal de Respuesta a Incidentes. En general, hemos encontrado una tendencia a m[illegible]spreciar la materialización de riesgos que se inician en dispositivos finales. Creemos que es una visión que pone en peligro a la organización. Asumir que por estar en nube, no hay que preocuparse de las estaciones finales suele ser un error que además viola principios básicos de la seguridad actual como Zero Trust y Defensa en Profundidad. Solo como una de múltiples referencias, sugerimos ver este documento[20].

Se han detectado elementos que afectan la recolección de evidencias durante el proceso forense:

Hallazgos:

1- No se ha determinado la prioridad (basada en volatilidad) de las evidencias. Como gran parte de la evidencia es volátil, es muy importante que esta sea recabada con prioridad sobre otros elementos que no lo son. Por lo general, las organizaciones cometen errores es este paso y se pierden elementos críticos para la investigación.
2- No existe un inventario formal de que se debe recolectar en cada caso ni de los procedimientos para la preservación correcta. No todos los elementos puede ser recolectados de la misma forma. Por ejemplo, un disco en un servicio en nube no está sometido a los mismos procesos (o estos son inútiles) que un disco en un equipo local.
3- En las estaciones de trabajo no hay un procedimiento establecido de respaldo, salvo los datos de las aplicaciones. Por lo tanto, no es posible preservar información de registros, acciones de usuarios y configuración que son importantes para identificar el origen de un incidente.

[20] https://expertinsights.com/insights/50-endpoint-security-stats-you-should-know/

CONFIDENCIAL

Recomendaciones:

1- Sugerimos enfáticamente establecer un esquema de recolección de evidencias que comience por los elementos más volátiles (RAM, rutas, cache). Ver los siguientes documentos: INTERPOL[21] , IETF[22].
2- Sugerimos que el documento de IR incluya los procedimientos específicos para cada fuente general de datos. Esta clasificación debe incluir, al menos: móviles, dispositivos de seguridad y comunicaciones, servicios en nube de cómputo, servicios en nube ofimáticos, dispositivos finales, servicios SaaS.
3- Se debe incluir en los procesos de respaldo formales las estaciones de trabajo como mecanismo de preservación de evidencias en casos de intrusiones que comiencen por ese medio. Sugerimos que además se establezca un esquema regular de revisión de la calidad de operación. Ver referencia a ISM3 en páginas anteriores.

IV. Procedimiento de evaluación de la relevancia forense de las evidencias

Nivel preparación: 2

Hallazgos:

1- No se ha establecido un esquema de ponderación de la relevancia de las evidencias a preservar, por lo que este proceso depende la intuición, y experiencia del equipo y no de un mecanismo metodológicamente guiado y maduro. Como consecuencia en ante un evento de seguridad pudiera darse pérdida de información relevante debido a desconocimiento de su relevancia. Como mencionamos en otros acápites esta situación puede ser aún mas riesgosa debido a la falta de métodos de recolección y de la definición del ciclo de vida de cada elemento.
2- Tampoco existe un inventario detallado de que evidencias deben recolectarse en según el tipo de incidente.
3- Aunque existe un plan de Respuesta a Incidentes (cuya evaluación detallada no es objetivo de este informe) la inexistencia de un esquema de recolección de evidencias puede producir errores de clasificación, manejo, preservación que no solo tiene impacto en la factibilidad y expectativas

[21] https://www.interpol.int/content/download/16243/file/Guidelines%20to%20Digital%20Forensics%20First%20Responders_V7.pdf

[22] https://datatracker.ietf.org/doc/html/rfc3227

CONFIDENCIAL

de éxito de un proceso forense, sino incluso podrían tener repercusiones legales al momento de rendir cuenta ante los organismos de control.

Recomendaciones:

1- Sugerimos enfáticamente que la organización haga un proceso de análisis de impacto de negocio (BIA) para definir prioridades en el proceso de recolección. Si bien los procesos BIA pueden ser muy complejos y se tenga la tendencia a menospreciar su importancia dentro del ciclo de seguridad (Riesgos-BIA-Controles-Evaluación Sistemática de Controles) sugerimos que al menos se realice para el proceso de recolección. El Ministerio de las TIC de Colombia tiene un documento general que puede servir de referencia[23], aunque sugerimos ver adicionalmente los siguientes documentos: Gartner[24], NIST[25].

2- Es muy importante que *a priori* se haga un inventario detallado de fuentes de evidencia. Sugerimos que se asocien al método de recolección y priorización (volatilidad). Sin pretender ser completos este inventario debe incluir:

a. Registros (hive) de usuarios finales
b. Registros de servidores
c. Bitácoras de operación de las aplicaciones
d. Bitácoras del servicio SOC
e. Bitácoras de los servicios contratados en nube
f. Bitácoras de estaciones de trabajo (al menos de usuarios privilegiados)
g. Bitácoras del sistema IAM
h. Bitácoras de cambios, incluyendo PAM y FIM si existen
i. Backups de servidores
j. Backups de estaciones de trabajo (al menos de usuarios privilegiados)
k. Backups de equipos/sistemas de seguridad.

Para cada elemento sugerimos que el inventario defina localización, tiempo de almacenamiento y una referencia a los métodos de recolección aplicables.

Nota adicional: En aproximadamente 70% (solo en el año 2022) de nuestros casos forenses nos encontramos con el escenario que el usuario no sabe dónde están, no ha preservado o ha extraído inadecuadamente las fuentes de información. Esto nos impide dar respuestas al proceso forense o a las autoridades competentes.

[23] https://www.mintic.gov.co/gestionti/615/articles-5482_G11_Analisis_Impacto.pdf
[24] https://www.gartner.com/en/information-technology/glossary/bia-business-impact-analysis
[25] https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-34r1.pdf

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

V. Tiempo de preservación de evidencias

Nivel de preparación: 4

Los tiempos de preservación de las evidencias varían notablemente dependiendo del sistema. y no han sido homogenizados, pero en general son satisfactorios siempre y cuando el proceso forense inicie antes de 30 días de ocurrido el incidente. Este período se ha definido a partir de la peor condición de retención (datawarehouse).

Al momento de realizar este informe no fue posible revisar los períodos de retención del servicio SOC que iba a ser contratado. Sin embargo, se sugiere que sean de al menos 1 año para garantizar cumplimientos regulatorios como GDPR y PCI.

Sugerencia:

En nuestra experiencia forense, lo más común es necesario tener fuentes de información de al menos 6 meses de antigüedad.

VI. Determinación del origen real del incidente

Nivel de preparación: 2

Hallazgos:

Aunque la arquitectura de la organización tiene elementos que valiosos para determinar el origen de un incidente si este ocurre internamente y dentro de los equipos servidores, existen una serie de factores que degradan el estado de cumplimiento y que describimos a continuación:

1- Al momento de realizar este informe el esquema de monitoreo SOC no estaba definido y no cubre (información entregada por el área de seguridad) las estaciones de trabajo que como hemos mencionado son el origen más común de incidentes.
2- El esquema de permisos y cambios es manual y verifica de la misma forma con períodos de 3 meses, por lo cual un incidente asociado a cambios de permisos no sería detectado antes. El esquema manual también abre el camino a posible falta de evidencia.
3- No existen mecanismos formales para detectar fallas de segregación de funciones.

CONFIDENCIAL

4- No existen esquemas formales de verificación de las acciones de cuentas privilegiadas (PAM) lo que permitirá a una de esas cuentas realizar acciones y eliminar evidencias. Estas acciones pueden ocurrir
5- Aunque existe un esquema de SGSI no se hacen revisiones en períodos regulares (cortos) de la calidad de la operación. Por lo tanto, un control puede degradarse sin que sea notado y podría afectar la capacidad de recabar información crítica desde el que permita detectar el origen o impacto de un incidente.

Recomendaciones:

1- Ver acápite en este informe sobre buenas prácticas de SOC. Ver ANEXO: en la página 26 de este documento.
2- Sugerimos que esquema FIM (ver en la página 8) incluya cambios en metadatos. Este tipo de cambios (que no se limita al contenido) se pueden obtener mediante un FIM criptográficos. Sugerimos que se incluya también localización de inodos (o MFT), propietarios, permisos y MAC Times. Sugerimos que la frecuencia de análisis nunca sea mayor a 24h (no 3 meses), por lo que debe automatizarse esta acción.
3- Ver sugerencias de servicio PAM en en la página 8.
4- La detección de fallos de segregación de funciones debe automatizarse. El esquema IAM de AWS tiene algunas funciones disponibles, aunque limitadas a sistema operativo y funciones del ambiente, no de aplicaciones. Sugerimos que se haga un análisis profundo de roles y perfiles en aplicaciones y se determinen combinaciones no aceptables o puntos de riesgo. Una vez realizada esta función, se pueden crear casos de uso en el SOC que detecten condiciones no aceptables tiempo cuasi-real.
5- Sugerimos montar un esquema de verificación regular de la calidad de la operación (no es válido asumir que solo la existencia de un control garantiza la seguridad). Recomendamos montar un esquema de auditoría externa, con frecuencia mensual, para detectar fallos o degradaciones en la calidad de la operación de los controles de seguridad. Sugerimos que se siga un esquema de madurez gradual.

VII. Determinación del alcance del incidente

Nivel de preparación: 3

Los puntos mencionados en el acápite anterior son aplicables a este. Por lo tanto, podrían afectar la determinación del alcance de un incidente en que hayan sido comprometidas cuentas privilegiadas.

CONFIDENCIAL

VIII. Determinación de los controles afectados.

Nivel de preparación: 4

Como mencionamos, la arquitectura de la organización es correcta (no confundir con su fiscalización) por lo tanto, sería posible determinar si algún control ha fallado o ha sido manipulado (aunque, como mencionamos previamente podría fallar la determinación de el origen y el método).

Sugerencia:

1- Sugerimos montar un esquema de verificación regular de la calidad de la operación (no es solo válido asumir que la existencia de un control garantiza la seguridad). Recomendamos montar un esquema de auditoría externa, con frecuencia mensual para detectar fallos o degradaciones en la calidad de la operación de los controles de seguridad. Sugerimos que se siga un esquema de madurez gradual.

La siguiente ilustración muestra el estado de preparación, tomando como referencias las fases (hitos) que debe contener un proceso forense.

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

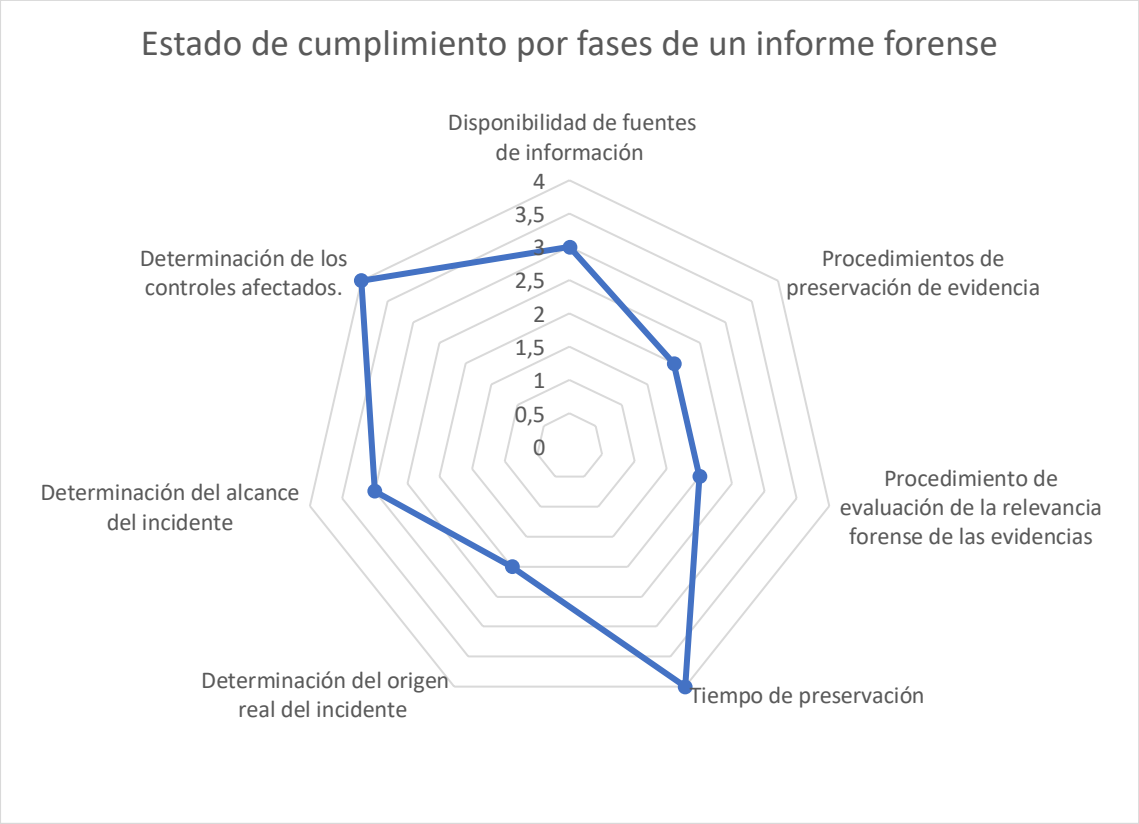

Ilustración 1Estado de preparación por fases.

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

IX. Nivel de preparación global para realizar forense sobre los ataques más comunes26

Hasta este momento, hemos identificado los componentes principales de un proceso forense general. En este acápite, utilizaremos un enfoque diferente: tomaremos en cuenta cual es la expectativa de "éxito forense" por tipo de ataque. Como en el resto del documento, hemos usado la escala descrita en la sección de metodología. Por favor notar que estas categorías de ataque corresponden a los casos más importantes reportados por las estadísticas internacionales para el año 2022.

CONFIDENCIAL

1. [26] https://www.cisco.com/c/es_mx/products/security/common-cyberattacks.html
2. https://www.google.com/url?sa=t&rct=j&q=&esrc=s&source=web&cd=&cad=rja&uact=8&ved=2ahUKEwiuhfjW8Mf-AhXOmWoFHePoCtQQFnoECA0QAQ&url=https%3A%2F%2Fwww.ibm.com%2Fes-es%2Freports%2Fthreat-intelligence&usg=AOvVaw2BTyrRRyIqPjQmi6wtXNNn
3. https://go.crowdstrike.com/2023-global-threat-report?utm_campaign=globalthreatreport&utm_content=crwd-laqu-en-x-tct-us-psp-x-wht-gtre-x_x_x_x-x&utm_medium=sem&utm_source=goog&utm_term=internet%20security%20threat%20report&gad=1&gclid=CjwKCAjwl6OiBhA2EiwAuUwWZRKNF7YLZwndoOJ4tJ1kRWQxLaoWTUSZxQosUbn_HpxWOi1SFZzegxoC4PIQAvD_BwE
4. https://www.google.com/aclk?sa=l&ai=DChcSEwjHl7SM8cf-AhVIIEwKHS1wDssYABABGgJvYQ&ae=2&sig=AOD64_2hKkQ94S0CPiDaW8mpaHkYpHxhdw&q&adurl&ved=2ahUKEwilrauM8cf-AhVIlGoFHTroA48Q0Qx6BAgHEAE

Tabla 2 Nivel de preparación por tipo de ataque.

Tipo de ataque	Nivel de preparación para forense
Negación de servicio sobre la plataforma de servidores	4
Malware sobre clientes finales	
Malware en servidores	4
Suplantación de identidad	2
Ataques de día 0	4
Errores de ciclo de desarrollo seguro (incluyendo explotación de vulnerabilidades en código)	4
Fraude interno	3

La razón de porque cada calificación puede verse a partir de la evaluación realizada en cada proceso en los acápites previos. Por ejemplo, un incidente de fraude interno está asociado a la acción con dolo o sin el de un colaborador. Como mencionamos previamente en este tipo de procesos es esencial para el forense poder determinar con exactitud los cambios en permisos y acciones de los que pudieran ser los atacantes. Sin embargo, por el tipo de gestión de identidades (incluyendo el control de cuentas privilegiadas), y la inexistencia real de un servicio SOC maduro puede ser muy difícil obtener la información adecuada. Un razonamiento similar puede hacerse para el caso de ataques que incluyan suplantación de identidades, en este caso sumándose la falta de vigilancia sobre estaciones finales, lo que permitiría a un atacante "robar" credenciales localmente y luego acceder con ellas a los servicios en nube.

Hay múltiples documentos que sirven de base a la enumeración de incidentes que hemos mostrado en está acápite. Sobre estos hemos hecho una selección de los que consideramos, a partir de la arquitectura de la organización que son los más probables. Esta selección se ha hecho en base de la información entregada por Simetrik, pero no constituye un análisis formal de riesgos. Sugerimos en especial ver el documento señalado en el pie de página #12 con el índice 4. Este corresponde a una prospectiva hacia el 2023 del estado de los incidentes de ciberseguridad a nivel mundial.

CONFIDENCIAL

X. Sobre la posible necesidad de reportar un incidente de seguridad.

Esta sección no constituye una guía formal de como reportar un incidente, pero si deseamos compartir algunas experiencias en este proceso. A continuación, mencionamos algunos elementos críticos:

1) Cada región o país tiene sus propias regulaciones aplicables, por lo tanto, lo mencionado a continuación debe estar regido por ellas.
2) No todo incidente tiene que implicar fuga de datos personales y los reportes deben ser cuidadosos de no emitir *juicios a priori* sin tener certidumbre.
3) Le sugerimos que en caso de ser necesario se contrate a un experto con experiencia demostrada para responder.
4) Los reguladores normalmente responden pidiendo información en tres líneas principales:
    a. Indicar que normas internas/políticas/procedimientos se han desarrollado para regular la actividad que dio origen al incidente.
    b. Indicar que controles técnicos se han habilitado para evitar la repetición del incidente.
    c. Indicar como se monitorea que los controles están siendo efectivos.

5) No debe suponerse que la indagación del regulador se limite al incidente, si se abre una investigación, el regulador puede tocar otros puntos del esquema de seguridad de la organización.

En general, desde el punto de vista técnico, será necesario responder y entregar evidencias de cumplimiento de los elementos descritos en la siguiente tabla. Además deberá aportarse evidencias de procedimientos/normas y políticas que cumplan no solo los elementos técnicos sino también jurídicos que el regulador espera.

ITEM
Controles perimetral
Descripción de control
Se revisa todo el tráfico cifrado en búsqueda de malware, intentos de intrusión, acceso de sitios maliciosos o fuga de información
El control de malware está definido para todo el tráfico entrante o saliente
El control de intruso está definido para todo el tráfico entrante o saliente
Las reglas están definidas en función del tipo de tráfico y no de simple origen-destino

CONFIDENCIAL

Velasco & Calle D'Aleman
Derecho de TIC / Ciberseguridad

Los objetos son creados lo más granular posible (redes, host, puertos, etc)
Las reglas están definidas separando tipo de tráfico (Ej. TCP separado de UDP, separado de ICMP)
Se definen criterios de QoS para cada regla, especialmente para aquellas que manejas protocolos sin Control de Flujo (UDP-ICMP)
Cuando se hace SSL-Drecrypt se realiza inspección completa (no solo validez de certificados)
Prevención y gestión de malware
Descripción del control
____% de equipos finales cubiertos por solución antimalware
Los errores del sistema antimalware se manejan como incientes de seguridad
Las alertas del sistema antimalware se manejan como incidentes de seguridad
La configuración del sistema antimalware impiden cambios en su configuración (incluyendo detener el servicio)
Gestión de Vulnerabilidades
Descripción de control
Procedimiento de evaluación de vulnerabilidades
Procedimiento de actualización
Seguimiento continuo de calidad de gestión
Se ha establecido sagas máximas de desactualización
Gestión de privilegios
Descripción de control
Existe un diseño definido de roles y perfiles
Se fiscaliza la asignación de roles y perfiles dentro de los S. Operativos.
Se fiscaliza la asignación de roles y perfiles dentro de las aplicaciones
Se fiscaliza el uso de cuentas de administrador (o grupo equivalente)
Se fiscalizan asignaciones de cuentas con permisos administrativos
Se fiscaliza cambios en parámetros en cuentas con permisos administrativos
Control de usuarios

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

Cuando se crean usuario se asignan privilegios mínimos de acuerdo a las funciones.
Cuando se crea usuarios se asignan credenciales robustas
Se ha asignado un período máximo de validez para todas las contraseñas
Se ha asignado un período mínimo de validez para todas las contraseñas
Se ha asignado un período máximo de inactividad para todas las cuentas de usuario
Existe un procedimiento de bloqueo de cuentas inactivas
Se fiscaliza mediante un esquema SOC/SIEM cambios en las políticas de usuarios
Se fiscaliza mediante un esquema SOC/SIEM intentos de intrusión usando cuentas de usuarios
Se fiscalizan accesos no habituales a cuentas de usuarios
No existen cuentas de usuarios que se usen como cuentas de servicio
Existe un inventario detallado de las cuentas de servicio activas
Los usuarios utilizan los dispositivos finales con cuentas que no tiene privilegios de administrador local
Arquitectura de Seguridad
Existen zonas de seguridad diferenciadas según un perfil de riesgo
El paso entre zonas de seguridad se fiscaliza y controla mediante dispositivos de seguridad
El acceso a los dispositivos está limitado por zonas
El acceso a las herramientas de software está limitado por zonas
Se fiscaliza el tráfico entre zonas de seguridad
Continuidad de Negocios/ DRP
Existe un procedimiento de continuidad de negocios
Existe un procedimiento de recuperación de desastres que cubre a IT
Se han realizado ejercicios de simulación de incidentes y estos han sido evaluados
Existen responsables designados y entrenados en procedimientos de recuperación de desastres (para IT) y continuidad de negocios
Se han realizado ejercicios de divulgación de los planes de continuidad y recuperación (para IT)
Evaluación de la seguridad
Se cuenta con un esquema de evaluación/auditoria continua que permita detectar fallas de operación
Se realizan pruebas técnicas profundas a la arquitectura de seguridad
Se realizan pruebas internas de seguridad por terceros

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

Velasco & Calle D'Aleman
Derecho de TIC / Ciberseguridad

Se realizan pruebas externas de seguridad por terceros
Se cuenta con certificaciones de seguridad asociadas a la operación de IT. Cúales?
Monitoreo de seguridad
Se cuenta con un esquema SOC/SIEM manejado por IT. Modelo
Se cuenta con un esquema SOC/SIEM manejado por terceros (evitar fraude interno)
El sistema SOC /SIEM cubre a todos los servidores
El sistema SOC/SIEM cubre a todas estaciones de trabajo
El sistema SOC/SIEM genera alertas en tiempo real
El sistema SOC/SIEM tiene ____ casos de uso documentados
El sistema SOC/SIEM es capaz de realizar acciones automáticas para al detectar incidentes
Existe un sistema FIM que alimenta al SOC/SIEM
Existe un sistema PAM que alimenta al SOC/SIEM
Existe un sistema IAM que alimenta al SOC/SIEM
Existe un procedimiento de mejora/ampliación de casos de uso de el sistema SIEM/SOC
El sistema SOC/SIEM cumple funciones SOAR
El sistema SOC/SIEM cumple funciones EDR
El sistema SOC/SIEM cumple funciones XDR
Organización institucional de la seguridad
La organización tiene definido un esquema funcional que cubre TODOS los requisitos de seguridad (confidencialidad, disponibilidad, integridad y los derivados de estos)
Existe un procedimiento táctico para la interacción de las áreas de seguridad e IT
Existe en espacio en que la gerencia principal es informada de manera regular del estado de la seguridad
Existen cronogramad de inversión en seguridad y ciberseguridad (CAPEX y OPEX)
Se fiscalizan las inversiones en seguridad y ciberseguridad
Existe un comité asesor de seguridad y ciberseguridad
Existe un área de experta en seguridad que realiza procesos de auditoria de ciberseguridad y seguridad informática.
Controles de cambio

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

Existe un procedimiento de control de cambios en funciones/aplicaciones y servicios de IT
Existe un procedimiento de control de cambios en funciones/aplicaciones y servicios de ciberseguridad y seguridad I.
Se fiscaliza que los cambios en la arquitectura, servicios, equipos, aplicaciones u otros pasen por control de cambio
Se fiscaliza que los cambios en la arquitectura, servicios, equipos, aplicaciones u otros correspondan con los autorizados en control de cambio
Se ha definido formalmente los responsables de las autorizaciones de cambios
Se han definido formalmente los responsables de cambios de emergencia
Existe un responsable por seguridad de analizar el impacto en seguridad de los cambios
Ciclo de vida y control de aplicaciones
Las aplicaciones se evalúan desde el punto de vista de seguridad
Existe un procedimiento aprobado para la evaluación de la seguridad de las aplicaciones
Existe un procedimiento formal de revisión estática y dinámico de código
____% de las aplicaciones han sido evaluadas con procedimientos formales de seguridad de código
____% de las aplicaciones han pasado satisfactoriamente los procesos de revisión de código.
Entrenamiento y cultura de seguridad
Existe un programa de entrenamiento general para todo el personal en seguridad de los sistemas
Existe un programa de entrenamiento específico en seguridad para miembros de IT.
Existe un programa de formación y entrenamiento evaluado para miembros del equipo de seguridad.
_____% de personal general entrenado
____% de personal de IT entrenado
____% de personal de seguridad entrenado
Cursos o entrenamiento en seguridad tomado por el personal de área en el último año.
Seguridad de Proveedores
Existe un procedimiento aprobado para la evaluación de la seguridad en el tratamiento de datos que hacen los proveedores
Existe un procedimiento aprobado para la evaluación de la seguridad de la operación los proveedores
Existe un procedimiento para la fiscalización del manejo de información por proveedores.

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

Velasco & Calle D'Aleman

Derecho de TIC / Ciberseguridad

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

Velasco & Calle D'Aleman
Derecho de TIC / Ciberseguridad

Conclusiones

Los valores con que hemos clasificado el estado de preparación de la organización son categóricos, por lo tanto, no tiene sentido realizar sobre ellas acciones como promedios u otros indicadores de tendencia central. Por el contrario, la falta de alguno de estos elementos puede afectar notablemente el éxito del proceso forense. Por esa razón sugerimos trabajar en cubrir los elementos que han sido señalados en este informe. En especial, los esquemas de verificación automatizada e independiente (por ejemplo, mediante un SOC bien definido) y el nivel de cubrimiento de seguridad son críticos.

Creemos que la **arquitectura de IT** de la organización es robusta y está bien administrada. Adicionalmente, el personal de IT que participó en el proceso fue diligente y demostró conocimiento y control sobre la misma.

Les sugerimos hacer una revisión más profunda de los temas de arquitectura de seguridad. Posiblemente, haciendo algunos ajustes a esta, la posición ante un proceso forense mejore significativamente. Sugerimos que se analicen los múltiples ddocumentos y estadísticas que hemos aportado en este documento para hacer un análisis real de riesgos. Sugerimos que este proceso se haga con acompañamiento externo experto que pueda dar una visión real y no comprometida de su arquitectura de seguridad.

Creemos que también se debe hacer una revisión de procedimientos de manera que cumplan no solo desde el punto de vista técnico sino también aquellos elementos que solicita el regulador u otros entes de control.

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic

XI. ANEXO: Requisitos técnicos de un servicio SOC efectivo.

1- La solución debe cubrir al menos XX nodos distribuidos a nivel nacional. Por nodo se entiende una fuente de información independiente entre las que se encuentran:

a) Servidores MS Windows
b) Directorio activo
c) Office365
d)Servidores Linux
e) Firewalls
f) Antimalware
g) Email Security
h)Estaciones de trabajo
i) Arquitectura SaaS
f) Aplicaciones
g) Arquitectura en nube.

2- La solución debe ser capaz de tener agentes activos capaces de automatizar la respuesta. Cuando no sea posible la instalación directa de agentes, deberán activar mecanismos alternativos de recolección de información.

3- La solución debe proveer al menos 300 casos de uso aplicables a la infraestructura. Estos casos de uso deben incluir, pero no limitarse a:

- Cambios de configuración
- Detección de ataques (siguiendo la clasificación de Técnicas de Mitre Attack)
- Detección de comportamientos no habituales (NTBA, UEBA)
- Cambios en archivos críticos (incluyendo ejecutables y bibliotecas)
-Protección de dispositivos finales (XDR)
- Monitoreo de bases de datos
-Gestión de vulnerabilidades

4- La solución debe poderse integrar a fuentes de inteligencia externas (provistas por el proveedor) para la detección, clasificación y respuestas.

5- La solución debe ser capaz de mantener su operación incluso si los dispositivos cambian su localización o canal de comunicación.

6- Los motores de correlación deben estar en nube.

CONFIDENCIAL

7- El transporte de datos debe ser cifrado usando protocolos criptográficamente robustos. Esto es AES 256, RSA 4096, ECC 256, TLS 1.2 o 1.3. SHA 2-3

8- La solución debe ofrecer un dashborad en tiempo real con todos los detalles de la operación de servicio directamente sobre solución.

9- La solución deben permitir validar en tiempo real el nivel de cumplimiento contra estándares internacionales (comparación contra plantillas de cumplimiento)

II- ANS (Tiempos sugeridos)

Alerta temprana (medida desde el momento de detectado en evento)

Incidentes graves: 30 min
Incidentes de impacto medio: 1h
Incidentes de bajo impacto: 1,5 h

LA ORGANIZACIÓN y el proveedor acordarán la definición de la clasificación de cada incidente en los primeros 10 días del servicio.

Informe final del incidente: 4 h (después de la alerta temprana).

Respuesta automatizada: 30 minutos después de la alerta temprana.

III- Sobre el servicio de monitoreo

1- El proveedor deberá ofrecer el servicio de monitoreo continuo, clasificación, priorización y alerta según los requisitos ANS que se exponen en la sección correspondiente.
2- El proveedor deberá, en caso de incidente, reportar a LA ORGANIZACIÓN por al menos 2 canales independientes a convenir por las partes, con tiempos nunca superiores a los especificados en las ANS.
3- El proveedor ofrecerá el servicio 24x7x365

IV- Responsabilidad del proveedor:

El proveedor es responsable de la seguridad de su plataforma y de los datos que maneja. Por lo tanto, debe garantizar mantener la seguridad de la misma en todo momento y cumplir los requisitos y normas de operación de la organización, incluyendo la confidencialidad, integridad y disponibilidad del servicio y los datos la organización o terceros manejados mediante el servicio. Bajo este criterio, es responsabilidad del proveedor mantener las actualizaciones, parches y ajustes que se requieran para garantizar la operación correcta del servicios.
El proveedor debe garantizar al menos el 99.98 % de disponibilidad anual del servicio.
El proveedor debe garantizar que su plataforma no pueda ser utilizada como punto de acceso para producir ataques (incluyendo degradaciones de la disponibilidad, fuga de información, detalles de la organización de datos u otros) sobre cualquier parte de la plataforma de la organización o terceros.

CONFIDENCIAL

El proveedor es responsable de la actitud, conocimientos y comportamiento técnico y ético de su personal, siendo totalmente responsable de demostrar ante LA ORGANIZACIÓN y/o autoridades que lo requieran, la actuación de su personal.
El proveedor es responsable de NO utilizar protocolos débiles que puedan poner el riesgo la seguridad del servicio y de los datos que maneja.
El proveedor deberá entregar, al menos 45 días luego de iniciado el servicio, a la organización sus protocolos generales de operación, incluyendo su plan de Respuesta a Incidentes y Recuperación de Desastres para el servicio objeto de la propuesta.
El proveedor acepta que LA ORGANIZACIÓN realizará revisiones regulares de la seguridad del servicio, por lo cual deberá discutir con LA ORGANIZACIÓN los resultados y plantear e implementar planes de mejora de encontrarse condiciones de riesgo que puedan poner en peligro la operación del servicio, de cualquier parte de los componentes de la arquitectura de la LA ORGANIZACIÓN , de su prestigio, sus datos o de terceros. LA ORGANIZACIÓN validará la ejecución de esos planes y podrá realizar nuevas pruebas para asegurarse que los riesgos han sido superados

V- Rendición de cuentas

*El proveedor deberá entregar un informe técnico **mensual** con las estadísticas del servicio, así como el análisis de incidentes (si ocurriesen).*
Las estadísticas deberán incluir al menos:
-Cantidad de eventos evaluados
-Cantidad y descripción de los incidentes
-Estado de cumplimiento de la gestión de vulnerabilidades
-Informe FIM
-TOP 20 de equipos afectados
-Top 20 de intentos de intrusión
-Top 20 de orígenes de intentos de intrusión
-Recomendaciones

VI- Control de cambios sobre la configuración de la solución

LA ORGANIZACIÓN deben aprobar cualquier cambio que se realice sobre la plataforma, incluyendo cambios de emergencia.
Los deben ser aprobados por el comité de cambios de seguridad o en su falta por el CISO (Director de Ciberseguridad Y el Director de Tecnología o equivalentes funcionales). Los cambios de emergencia pueden ser aprobados por el Director de Ciberseguridad y/o el Director de Tecnología o sus equivalentes funcionales.
El proveedor deberá entregar, al menos, antes de realizar el cambio los siguientes elementos:
a) Descripción técnica del cambio
b)Justificación del cambio
c)Impacto del cambio
d)Plan de rollback
e)Recursos involucrados
f)Afectación del servicio (si lo hubiese).

CONFIDENCIAL

Una vez realizado el cambio, el proveedor deberá informar y certificar a LA ORGANIZACIÓN los resultados y la validación de que la razón del cambio ha sido superada. La entrega de esta información se realizará por correo electrónico dirigido al Director de Ciberseguridad y al Director de Tecnología.

VII-Acceso a la plataforma.

El proveedor deberá entregar a LA ORGANIZACIÓN accesos de lectura para la fiscalización de la operación. Este acceso debe ser directo a la plataforma de monitoreo.

VIII- Planes de mejora.

El proveedor deberá destinar los recursos necesarios para implementar planes de mejora continua sobre el servicio objeto de esta propuesta. Estos planes deberán discutirse con LA ORGANIZACIÓN y deberá ser sometidos a los procedimientos de control de cambio que se han descrito previamente.

IX- Atención a los requerimiento de información de LA ORGANIZACIÓN o autoridades
El proveedor deberá responder a los requerimientos de información de la organización y/o autoridades referidas a respuesta incidentes, procesos forenses, procesos de investigación u otros.

X- Atención a medidas de emergencia.
El proveedor deberá implementar controles de emergencia en caso de ser necesarios. Estos controles deberán ser sometidos a los procedimientos de control de cambios que se han descrito previamente como cambios de emergencia. El origen de estos requerimientos puede estar en el propio proveedor (ante la detección de una amenaza) o en la organización mediante solicitud del Director de Ciberseguridad.

*XI***- Respuesta a incidentes**

El proveedor deberá participar, ofreciendo los datos necesarios, en caso de la ocurrencia de algún incidente que requiera su participación de acuerdo a los requisitos de este documento.

XII-Preservación de datos

El proveedor deberá preservar al menos 1 (un) año los datos de monitoreo y reportes del servicio.

CONFIDENCIAL

Velasco & Calle D'Aleman

Derecho de TIC / Ciberseguridad

CONFIDENCIAL

Carrera 34 # 11B - 70 oficina 602
Medellin - Antioquia
3024035688
(604) 479 5208
www.velascocalle.co
linkedin.com/in/velascocalletic